

Pipeline CI/CD sécurisée

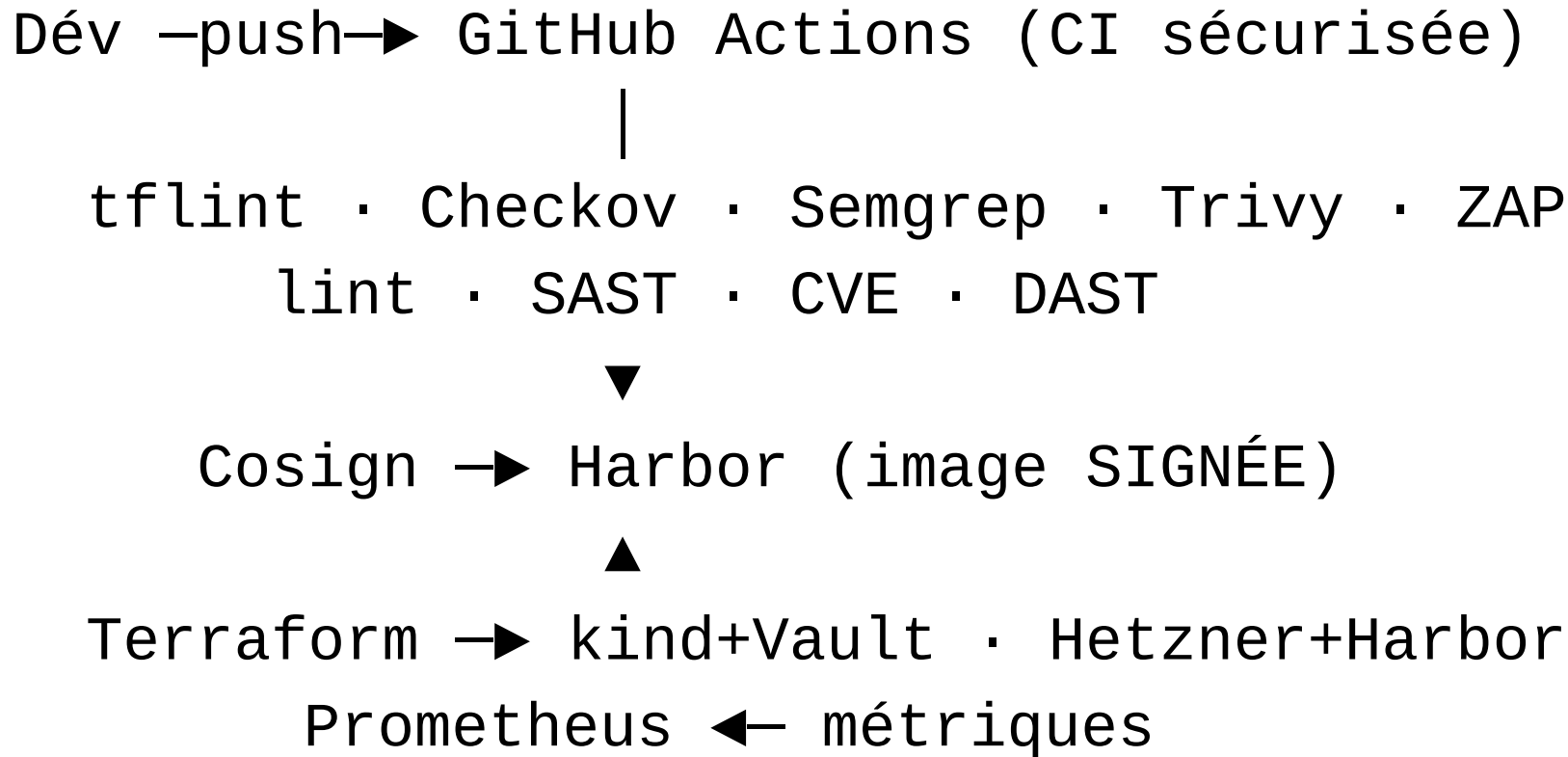
Vault · Terraform · GitHub Actions — Module
DevSecOps

Groupe DevSecOps

DevSecOps & shift-left

- **DevSecOps** : la sécurité intégrée et **automatisée** dans tout le cycle de vie
- **Shift-left** : détecter au plus tôt = corriger moins cher
- À chaque git push, la pipeline contrôle : code · dépendances · image · application · signature
- 3 piliers : organisationnel · technique · culturel

Architecture globale



Infrastructure as Code sécurisée

- terraform/ → **Vault** sur **kind** (Helm)
- terraform/harbor/ → **VPS Hetzner** + **Harbor** (cloud-init, **TLS Let's Encrypt**)
- Secrets **hors du code** (.tfvars + state gitignorés)
- Pare-feu restrictif (22/80/443) · providers figés (lockfile)

La pipeline CI/CD sécurisée

Pipeline **bloquante** : un contrôle échoue → rien n'est publié · lint → SAST → CVE → DAST → signature

Intégration Continue — Vault + Terraform + GitHub Actions

✓ Success

staging · push · 8 jobs · pipeline bloquante

Jobs	
✓ Terraform Format	9s
✓ Terraform Validate	7s
✓ TFLint Scanning	5s
✓ Checkov Security Scanning	27s
✓ Semgrep — Analyse de sécurité	25s
✓ trivy-scan	22s
✓ ZAP Baseline Scan	1m 36s
✓ Build, Push & Sign (Harbor)	29s

lint → SAST → CVE → DAST → signature · tout vert = artefact publié et signé

Analyse statique (SAST / IaC)

- **TFLint** → qualité du code Terraform (les 2 modules)
- **Checkov** → sécurité IaC + Dockerfile + workflows
- **Semgrep** → SAST du code source (p/security-audit)
- Résultats au format standard **SARIF**

Analyse dynamique (CVE & DAST)

- **Trivy** → **CVE** de l'image (OS + dépendances), HIGH/CRITICAL
- **OWASP ZAP** (baseline) → **DAST** : teste l'application **en cours d'exécution**
- Image de base **durcie** (nginx non-root, port non privilégié)

Sécuriser la création d'artefact : Cosign

build → push → sign → verify (gate)

· **Supply chain** : origine + intégrité garanties

Projets / devsecops / Dépôts

moteur-recherche

Info Artefacts

Lancer le scan de vulnérabilités

Générer le SBOM

Actions

Artefacts	Tags	Signé	Taille	Date d'envoi
 sha256:0a30d0f8...	sha-30bc95b...		20.03 MiB	2026-06-24
 sha256:eb408ead...	sha-8bcadd...		20.03 MiB	2026-06-24

1 – 2 sur 2 entrées · image signée par Cosign (signature.cosign)

Gestion des secrets : Vault

- **HashiCorp Vault** déployé via Terraform/Helm
- Aucun secret **en clair** dans le code ni les images
- CI : **GitHub Secrets** + **robot account** Harbor (**moindre privilège**)

Observabilité (architecture cible)

Vault → /sys/metrics (format Prometheus)

Harbor → exporter

|

Prometheus (scrape)

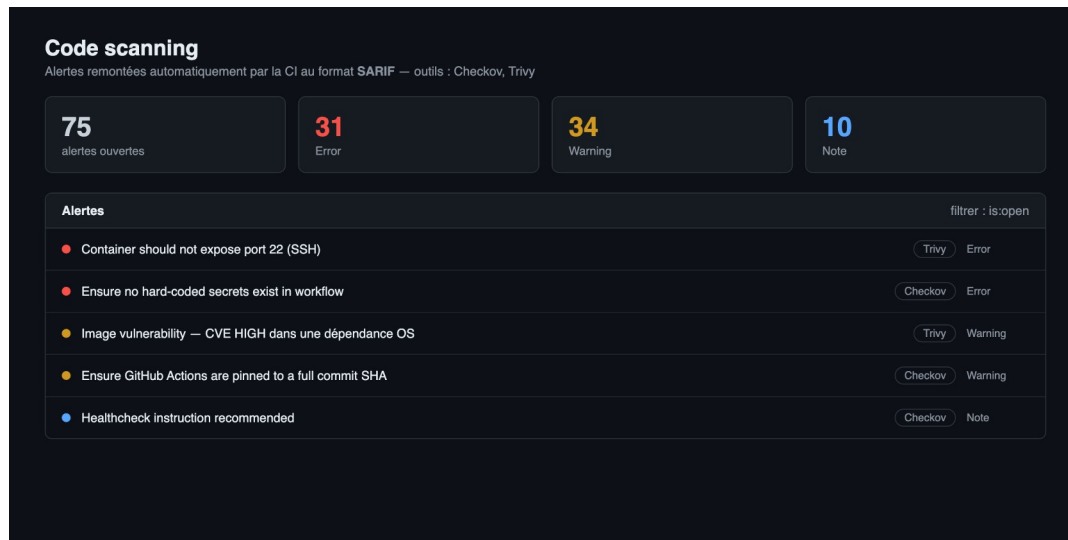
|

Dashboard (Grafana)

- Supervisor : **accès aux secrets** · santé du registre · état de l'infra

Communiquer les informations de sécurité

Tous les outils → **SARIF** → onglet **Security**
GitHub · **visibilité centralisée**



Bilan & conclusion

-  IaC sécurisée · pipeline **bloquante** (lint, SAST, CVE, DAST) · artefact **signé** · secrets gérés · sécurité **centralisée**
-  SOON Finaliser le dashboard Prometheus · custom checks Checkov · restreindre le SSH
- **Shift-left de bout en bout** — du commit à l'artefact signé